

GUÍA COMPLETA DE AUDITORÍA DE SEGURIDAD WINDOWS

Para el examen de Seguridad de Datos

Visor de eventos, directivas de seguridad, IDs de eventos y análisis forense

Contenido basado en la Práctica 4 – Monitorización y Auditoría de Seguridad (parte Online)

HERRAMIENTAS CLAVE

Acceso rápido a cada herramienta

Herramienta	Comando consola	Ruta de menú
Visor de eventos	eventvwr	Inicio > Panel de control > Herramientas de Windows > Visor de eventos
Directiva local	secpol	Herramientas de Windows > Directiva de seguridad local
Editor directivas	gpedit.msc	Ejecutar > gpedit.msc
Firewall avanzado	wf.msc	Ejecutar > wf.msc

Consejo

CONSEJO: En el examen usa SIEMPRE los comandos de consola (eventvwr, secpol, gpedit.msc) en lugar de navegar por menús. Es mucho más rápido.

APARTADO 1: El Visor de Eventos (eventvwr)

Estructura del panel izquierdo

Registros de Windows

- Aplicación → eventos de aplicaciones instaladas
- Seguridad → AQUÍ están los eventos de auditoría de seguridad
- Instalación → eventos de instalación de software
- Sistema → eventos del SO (drivers, servicios)
- Eventos reenviados

Registros de aplicaciones y servicios

- Microsoft > Windows > Windows Firewall With Advanced Security
 - Firewall → cambios en reglas y configuración
 - Firewall detallado → estado operativo (deshabilitado por defecto)
 - Seguridad de conexión → configuración de reglas IPsec
 - Seguridad de conexión detallada → funcionamiento de IPsec

Filtrar eventos por fecha

1. Panel izquierdo → seleccionar registro (ej: Seguridad)
2. Panel derecho → “Filtrar registro actual...”
3. Campo “Registrado” → cambiar “En cualquier momento” por “Intervalo personalizado...”
4. Introducir fecha: desde 00:00:00 hasta 23:59:00 del día deseado

Guardar y cargar eventos filtrados

Guardar:

- Panel derecho → “Guardar archivo de registro filtrado como...” → nombre: EventosSegDia
- Formato del fichero: .evtx

Cargar:

- Menú Escaneo → “Abrir escaneo” (crea nueva ventana)
- O “Abrir escaneo en esta ventana” (añade al inventario actual)

Importante

IMPORTANTE: Borrar un elemento de "Registros guardados" en el Visor de eventos NO borra el fichero .evtx del disco. Solo elimina el acceso rápido desde el visor.

APARTADO 2: Directiva de Seguridad Local (secpol)

Estructura del panel izquierdo de secpol

Configuración de seguridad

- Directivas de cuenta
 - Directiva de contraseñas → longitud mínima, complejidad, expiración
 - Directiva de bloqueo de cuenta → intentos fallidos antes de bloqueo
- Directivas locales
 - Directiva de auditoría → 9 categorías básicas de auditoría
 - Asignación de derechos de usuario
 - Opciones de seguridad → aquí se activa la auditoría avanzada
- Windows Defender Firewall con seguridad avanzada
- Configuración de directiva de auditoría avanzada ← USAR ESTO en el examen

Activar la Auditoría Avanzada (OBLIGATORIO en la asignatura)

1. En secpol → "Directivas locales" → "Opciones de seguridad"
2. Buscar la directiva: "**Auditoría: forzar la configuración de subcategorías...**"
3. Doble clic → seleccionar "**Habilitada**" → Aceptar
4. Ahora el último nodo del panel izquierdo muestra la "Configuración de directiva de auditoría avanzada"

Importante

IMPORTANTE: En la asignatura SLGD se debe usar SIEMPRE la Auditoría Avanzada, NO la directiva de auditoría básica (las 9 categorías simples).

Categorías de la Directiva de Auditoría Avanzada

Categoría	Subcategorías relevantes
Inicio y cierre de sesión	Auditar inicio de sesión, Cierre de sesión, Bloqueo de cuenta
Acceso a objetos	Auditar sistema de archivos, Registro, Kernel object
Uso de privilegios	Auditar uso de privilegios confidenciales
Seguimiento detallado	Auditar creación de procesos, terminación
Cambio de directiva	Auditar cambio de directiva de auditoría
Administración de cuentas	Auditar administración de cuentas de usuario/grupo
Acceso DS	Auditar cambios en Active Directory
Inicio de sesión de cuenta	Auditar validación de credenciales
Sistema	Auditar integridad del sistema de seguridad

Opciones de auditoría por categoría

Opción	Qué registra
(ninguna)	No auditar – no se generan eventos
Correcto	Solo operaciones exitosas (ej: logins correctos)
Erróneo	Solo operaciones fallidas (ej: contraseñas incorrectas)
Ambas	Correcto + Erróneo – máxima visibilidad

Consejo

CONSEJO: Para detectar ataques de fuerza bruta activar "Erróneo" en "Auditar inicio de sesión". Para auditar accesos a ficheros sensibles activar "Correcto" y "Erróneo" en "Auditar sistema de archivos".

APARTADO 3: IDs de Eventos de Seguridad de Windows

Eventos de Inicio/Cierre de Sesión (Logon/Logoff)

ID	Descripción
4624	Inicio de sesión correcto
4625	Error de inicio de sesión (contraseña incorrecta, cuenta inexistente, etc.)
4634	Cierre de sesión
4647	Cierre de sesión iniciado por el usuario
4648	Inicio de sesión con credenciales explícitas (runas, tareas programadas)
4649	Se detectó un ataque de repetición (replay attack)
4672	Inicio de sesión con privilegios especiales (administrador)
4778	Se reconectó una sesión de Escritorio Remoto
4779	Se desconectó una sesión de Escritorio Remoto

Eventos de Cuentas de Usuario

ID	Descripción
4720	Se creó una cuenta de usuario
4722	Se habilitó una cuenta de usuario
4723	El usuario intentó cambiar su contraseña
4724	Se restableció la contraseña de un usuario
4725	Se deshabilitó una cuenta de usuario
4726	Se eliminó una cuenta de usuario
4740	Se bloqueó una cuenta de usuario (por intentos fallidos)
4767	Se desbloqueó una cuenta de usuario
4776	El controlador de dominio intentó validar las credenciales (NTLM)

Eventos de Grupos

ID	Descripción
4727	Se creó un grupo global de seguridad
4728	Se agregó un miembro a un grupo global de seguridad
4729	Se quitó un miembro de un grupo global de seguridad
4731	Se creó un grupo local de seguridad
4732	Se agregó un miembro a un grupo local de seguridad
4733	Se quitó un miembro de un grupo local de seguridad
4756	Se agregó un miembro a un grupo universal de seguridad

Eventos de Acceso a Objetos (ficheros, carpetas, registro)

ID	Descripción
4656	Se solicitó un identificador a un objeto (intento de acceso)
4657	Se modificó un valor del Registro
4660	Se eliminó un objeto
4663	Se realizó un intento de acceso a un objeto (leer, escribir, ejecutar)
4670	Se cambiaron los permisos de un objeto

Importante

IMPORTANTE: Para que aparezcan eventos 4663 es necesario:

1. Activar "Auditar sistema de archivos" en la directiva avanzada.
2. Además ir a las Propiedades del fichero/carpetas → pestaña Seguridad → Opciones avanzadas → pestaña Auditoría → añadir las operaciones a auditar.

Eventos de Procesos

ID	Descripción
4688	Se creó un nuevo proceso
4689	Finalizó un proceso

Eventos del Sistema y Directivas

ID	Descripción
----	-------------

4608 Windows se está iniciando
 4609 Windows se está cerrando
 4616 Se cambió la hora del sistema
 4697 Se instaló un servicio en el sistema
 4719 Se cambió la directiva de auditoría del sistema
 4902 Se creó la tabla de directivas de auditoría por usuario
 4904/4905 Se registró/quité un origen de evento de seguridad

Eventos de Firewall de Windows

ID	Descripción
2003	Cambió una configuración de Firewall (perfil Público/Privado/Dominio) más general
2006	Se eliminó una regla de la lista de excepciones
2010	Cambió el perfil de red en una interfaz
2033	Se eliminaron TODAS las reglas (reseteo completo del Firewall)
2051	Actualización de directiva de restricciones de inquilino
2097	Se agregó una regla a la lista de excepciones
2099	Se modificó una regla de la lista de excepciones

Consejo

CONSEJO: Memorizar solo: 2097=añadir regla, 2099=modificar regla, 2006=eliminar regla, 2003=cambio de configuración general, 2033=borrado total.

Ruta del registro de Firewall en el Visor de Eventos

Registros de aplicaciones y servicios

> Microsoft > Windows > Windows Firewall With Advanced Security > Firewall

O directamente desde consola:

eventvwr

Y navegar hasta la ruta indicada.

APARTADO 4: Flujo de Trabajo en el Examen

Las 4 tareas secuenciales de auditoría

Tarea	Herramienta	Objetivo
1	secpol / Firewall	Activar y configurar controles de seguridad
2	secpol (avanzada)	Activar y configurar la auditoría para capturar eventos
3	Acciones manuales	Generar eventos (logins fallidos, acceder a ficheros, nmap, etc.)
4	eventvwr	Analizar y documentar los eventos capturados

Tarea 1 — Controles de seguridad:

- secpol → Directivas de cuenta → Directiva de contraseñas (longitud mínima, etc.)
- secpol → Directivas de cuenta → Directiva de bloqueo de cuenta
- Firewall → añadir/quitar reglas de entrada/salida
- Propiedades de fichero → pestaña Seguridad → permisos de acceso

Tarea 2 — Configurar auditoría:

- secpol → Opciones de seguridad → habilitar “Auditoría: forzar subcategorías...”
- secpol → Configuración de directiva de auditoría avanzada → seleccionar categoría
- Para cada subcategoría: elegir Correcto, Erróneo o ambas

Tarea 3 — Generar eventos de prueba:

- Cerrar sesión e intentar login con contraseña incorrecta (2-3 veces)
- Entrar finalmente con contraseña correcta
- Acceder a ficheros/carpetas auditadas

- Lanzar escaneo nmap contra el equipo para generar tráfico de red

Tarea 4 — Analizar eventos:

- eventvwr → Registros de Windows → Seguridad
- Filtrar por fecha o por ID de evento
- Buscar ID 4625 (login fallido) o 4624 (login correcto)
- Guardar como .evtx si el enunciado lo pide
- Captura de pantalla Alt+ImprPant de cada paso importante

Importante

IMPORTANTE: Si el examen pide entregar un documento de auditoría, documentar CADA PASO con capturas de pantalla (Alt+ImprPant) y texto explicativo mínimo. Guardar en .docx.

CHULETA RÁPIDA

IDs más importantes (los que más salen en examen)

ID	Descripción	Activar con
4624	Login correcto	Auditar inicio de sesión → Correcto
4625	Login FALLIDO (fuerza bruta)	Auditar inicio de sesión → Erróneo
4740	Cuenta BLOQUEADA (muchos intentos)	Auditar administración de cuentas
4720	Nueva cuenta creada	Auditar administración de cuentas
4663	Acceso a fichero/objeto	Auditar sistema de archivos + SACL
4688	Nuevo proceso creado	Auditar creación de procesos
2097	Regla de Firewall AÑADIDA	Registro Firewall en eventvwr
2006	Regla de Firewall ELIMINADA	Registro Firewall en eventvwr
2003	Configuración de Firewall CAMBIADA	Registro Firewall en eventvwr

Comandos de consola de referencia rápida

Comando	Qué abre
eventvwr	Visor de eventos
secpol	Directiva de seguridad local
gpedit.msc	Editor de directivas de grupo local
wf.msc	Firewall de Windows con seguridad avanzada

Ubicación de ficheros de eventos en el sistema

Tipo	Ruta por defecto
Seguridad	C:\Windows\System32\winevt\Logs\Security.evtx
Sistema	C:\Windows\System32\winevt\Logs\System.evtx
Aplicación	C:\Windows\System32\winevt\Logs\Application.evtx
Firewall	C:\Windows\System32\winevt\Logs\Microsoft-Windows-Windows Firewall With Advanced Security\Firewall.evtx

Trucos clave para el examen

1. **Ir directo al evento:** En eventvwr, clic derecho sobre “Seguridad” → “Buscar...” → escribir el ID
2. **Filtrar rápido:** Panel derecho → “Filtrar registro actual” → campo “IDs de eventos” → poner el ID
3. **Ver detalle:** Doble clic sobre un evento → pestaña “General” para descripción legible
4. **Correlación:** Si ves varios 4625 seguidos de un 4624 → intento de fuerza bruta exitoso
5. **Cuenta bloqueada:** 4740 confirma que el mecanismo de bloqueo funcionó correctamente
6. **Guardar filtrado:** Una vez filtrado, panel derecho → “Guardar archivo de registro filtrado como...”

PREGUNTAS TIPO EXAMEN

Visor de eventos

- a) Comando: `eventvwr`. Auditoría en Registros de Windows → Seguridad.
- b) Filtrar ayer: panel derecho → “Filtrar registro actual...” → Intervalo personalizado → 00:00:00 a 23:59:00.
- c) Guardar como `EventosSegDia` → extensión `.evtx`. Borrar en “Registros guardados” **no** borra el fichero del disco.
- d) Eventos de reglas de firewall: Registros de aplicaciones y servicios → Microsoft → Windows → Windows Firewall With Advanced Security → Firewall.

secpol y auditoría avanzada

- a) Paso previo: `secpol` → Directivas locales → Opciones de seguridad → “Auditoría: forzar la configuración de subcategorías...” → Habilitada.
- b) Contraseña incorrecta: categoría **Inicio y cierre de sesión** → Auditar inicio de sesión → Erróneo (o Ambas).
- c) Auditar fichero: no basta con “Auditar sistema de archivos” en `secpol`; hay que añadir **SACL** en Propiedades del fichero → Seguridad → Opciones avanzadas → pestaña **Auditoría**.
- d) IDs: fallido **4625**, correcto **4624**, cuenta bloqueada **4740**.

Análisis forense

- a) **4625** → **4625** → **4625** → **4624** = fuerza bruta o pruebas fallidas y luego éxito. Si sigue **4740** = cuenta bloqueada.
- b) Firewall: añadida **2097**, eliminada **2006**, todas borradas **2033** (modificada: **2099**).
- c) Evento **4625**: usuario, dominio, motivo del fallo, IP origen, fecha/hora.
- d) Verificar cambios de firewall sin tocar `secpol`: `eventvwr` → registro **Firewall** → buscar 2097/2099/2006/2033/2003 en el intervalo auditado.

Flujo completo con Nmap (Bloque C)

- a) Habilitar subcategorías → Auditar inicio de sesión → Correcto + Erróneo.
- b) Generar eventos: 2× login fallido + 1 correcto; desde otra máquina `nmap -T4 -A -v IP` (el escaneo no siempre deja huella en Seguridad; lo habitual son **4624/4625**).
- c) En Seguridad filtrar **4624** y **4625**; documentar usuario, timestamp y origen en el detalle del evento.
- d) Registro Firewall: si se tocó el firewall durante la práctica, correlacionar **2097** (regla añadida) u otros IDs; si solo hubo Nmap sin cambios, puede no haber eventos nuevos.

Consejo

CONSEJO: Correlación clásica — varios 4625 + un 4624 = posible fuerza bruta exitosa; 4740 confirma que el bloqueo de cuenta actuó.